PROJECT 1 • AI PROGRAMMING FOUNDATIONS

Reproducible CISA KEV Data Workflow

A transparent Python workflow for understanding actively exploited vulnerabilities.

EXECUTED ANALYSIS • REPRODUCIBLE ARTIFACT • RESPONSIBLE AI

Overview

This project builds an executable ingestion, cleaning, exploratory-analysis, and visualization workflow for the U.S. Cybersecurity and Infrastructure Security Agency Known Exploited Vulnerabilities (KEV) catalog. The official CSV snapshot contains 1,674 rows and 11 source columns and is analyzed as a vulnerability-management dataset rather than a predictive benchmark.

Dataset Description

CISA describes KEV as an authoritative catalog of vulnerabilities with evidence of exploitation in the wild. The snapshot spans 2021-11-03 through 2026-08-21, covers 278 vendor labels, and includes CVE, vendor, product, dates, required action, CWE, notes, and known ransomware-campaign use. The analysis focuses on vendor concentration, additions over time, remediation windows, and the ransomware field. Because the catalog records inclusion decisions, it does not represent every vulnerability or every exploitation event.

Workflow Description

The notebook reads the unchanged CSV, displays its shape and sample rows, and calls two documented cleaning functions. The first extracts a canonical first CWE identifier; the second trims selected text, parses dates, derives remediation days and a ransomware flag, and removes duplicate CVE identifiers without mutating the input. Assertions verify CVE uniqueness and non-negative remediation windows. A reusable summary function returns an audit dictionary, and three saved plots show top vendors, annual additions, and ransomware association.

This arrangement follows Danchev's (2022) recommendation to integrate real data, code, narrative, and outputs in a transparent computational workflow. It also reflects Rule et al.'s (2019) guidance that notebooks should explain analytical choices and be organized for rerunning and review.

Key Decisions and Assumptions

Dates with invalid syntax are coerced to missing instead of guessed. CWE normalization retains only the first canonical CWE because the visualization does not need a many-to-many expansion; the original field remains available. “Unknown” ransomware use is never changed to “No,” because absence of a known association is not negative evidence. Annual catalog additions are interpreted as catalog activity, not attack frequency. The vendor chart surfaces concentration, the time plot shows the catalog’s changing cadence, and the ransomware chart highlights a high-impact prioritization attribute.

Results and Interpretation

The workflow retained 1,674 unique catalog entries across 278 vendors. It identified 352 entries marked as associated with known ransomware campaigns and a median listed remediation window of 21 days. Figure 1 shows concentration among widely deployed vendors, while Figure 2 shows that additions vary markedly by year. Figure 3 makes the much smaller known-ransomware subset visible without treating the remainder as safe. The practical result is a defensible descriptive briefing, not a vulnerability-risk score.

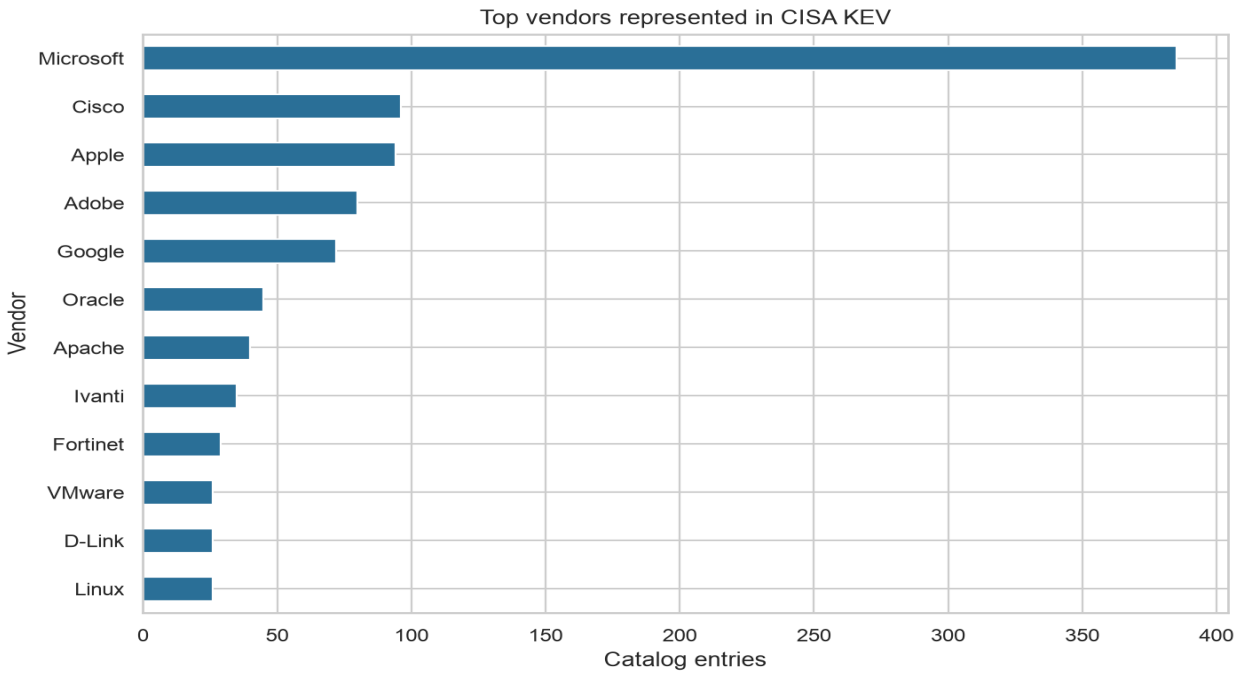


Figure 1. Catalog entries among the twelve most represented vendor labels.

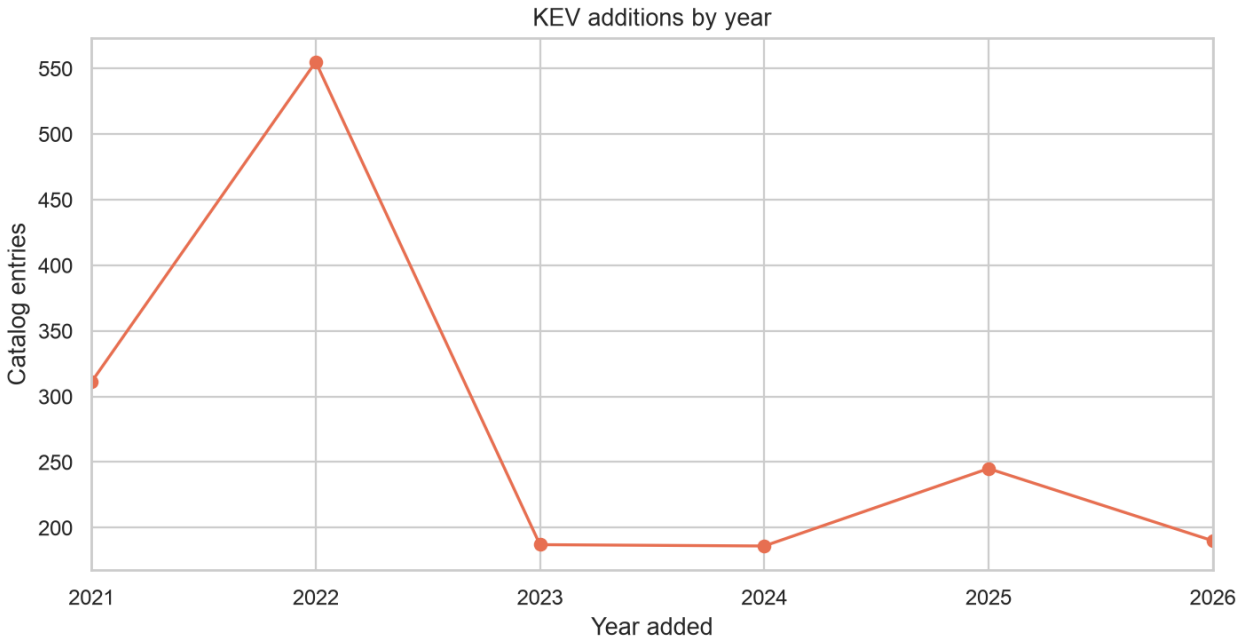


Figure 2. Annual additions reflect both exploitation evidence and catalog operations.

Responsible Practice (Bias and Data Quality)

Catalog inclusion depends on observed exploitation and CISA's evidence and publication process. Vendor prevalence, deployment scale, detection capability, disclosure incentives, and reporting delays can therefore affect representation. Cleaning can introduce further bias if redacted or nonstandard CWE values are discarded silently; the notebook retains raw fields and reports missing normalized CWE values. Any operational use should combine KEV status with asset exposure, business criticality, compensating controls, and local threat intelligence rather than ranking solely by vendor frequency.

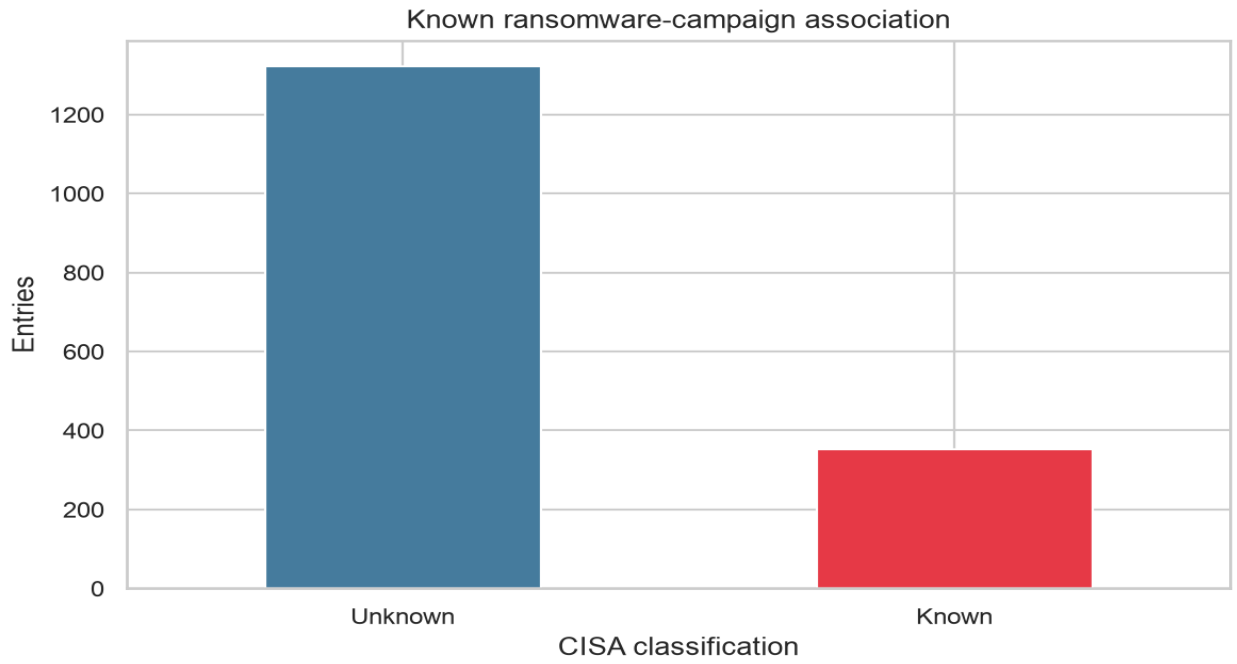


Figure 3. CISA ransomware-campaign classification; unknown does not mean absent.

Reproducibility

The folder includes the exact CSV snapshot, executed notebook, saved figures, pinned direct dependencies, and short run instructions. A reviewer can create an environment with `pip install -r requirements.txt` and run all cells from the project directory. The intended Git history separates data ingestion, cleaning functions, analysis, and reporting on a development branch before merge, making changes reviewable. The source URL and snapshot date should be recorded whenever the live catalog is refreshed because KEV changes over time.

References

Danchev, V. (2022). Reproducible Data Science with Python: An Open Learning Resource. *Journal of Open Source Education, 5*(56), 156. https://doi.org/10.21105/jose.00156

Rule, A., Birmingham, A., Zuniga, C., et al. (2019). Ten simple rules for writing and sharing computational analyses in Jupyter Notebooks. *PLOS Computational Biology, 15*(7), e1007007. https://doi.org/10.1371/journal.pcbi.1007007

Cybersecurity and Infrastructure Security Agency. (2026). Known Exploited Vulnerabilities Catalog. https://www.cisa.gov/known-exploited-vulnerabilities-catalog